Case 02 · מסמך ייזום: Private Exposure Registry

לפי פרק 1 (ייזום) בתבנית תיק הפרויקט של מגשימים. לכל פרויקט: תיאור כללי, מטרה, קהל יעד, פתרונות קיימים, ליבה טכנולוגית, טכנולוגיות, אתגרים ומקורות, דרישות חומרה, ומסקנה.

תיאור כללי

מערכת שמאפשרת לגופים פיננסיים לחבר את נתוני החשיפה שלהם לתמונה משותפת בלי לחשוף אותם, באמצעות חישוב רב-צדדי מאובטח (MPC), כדי שאפשר יהיה לראות סיכון שמצטבר בכל השוק, בזמן שכל משתתף רואה רק את הנתונים של עצמו.

בפועל: כל משתתף (קרן אשראי, בנק, קרן פנסיה) "מפצל" את הנתונים שלו לחלקים אקראיים ושולח כל חלק לשרת אחר. אף שרת לבדו לא יכול לשחזר שום דבר. השרתים מחשבים יחד, על החלקים המפוצלים, שאלות כמו "כמה אשראי ממונף בשוק תלוי בריבית מעל 5%?" או "האם יש ענף אחד שכל הקרנות חשופות אליו?". רק התשובה המצרפית נפתחת.

מטרת הפרויקט

בחרנו בפרויקט כי הסיפור מצביע על פרדוקס: הסכנה הגדולה ביותר היא החשיפה שאף אחד לא ראה, אבל הסיבה שאף אחד לא ראה היא שהנתונים סודיים. קרן לא תחשוף את הפוזיציות שלה למתחרים, ולעיתים גם לא לרגולטור של מדינה אחרת. כך נוצר שוק (האשראי הפרטי) שבו כל אחד יודע הכול על עצמו ואף אחד לא יודע כלום על השלם.

המטרה: להראות שאפשר לפרק את הפרדוקס הזה. לא צריך לבחור בין סודיות לבין שקיפות: אפשר לחשב על נתונים בלי לראות אותם.

קהל היעד

- **קהל עיקרי:** רשויות פיקוח ובנקים מרכזיים (בישראל, באירופה ובארה"ב), שצריכים תמונה מצרפית של שוק שהנתונים שלו מפוזרים בין גופים ומדינות. ידע נדרש: הבנה בסיכון פיננסי; הקריפטוגרפיה שקופה להם.
- **קהל משני:** איגודי תעשייה וקבוצות של גופים פיננסיים שרוצים להשוות את עצמם לממוצע הענפי ("האם אנחנו חשופים יותר מהאחרים?") בלי לחשוף נתונים.
- **תרחיש להמחשה:** שלושה רגולטורים (בריטניה, צרפת, ארה"ב) רוצים לדעת אם אותן קרנות אשראי ממונפות חשופות לאותן חברות בשלוש המדינות. אף אחד מהם לא מורשה לשלוח את הנתונים שלו לאחרים. הם מריצים את השאלה דרך הרשם, ומקבלים רק את התשובה המשותפת.

פתרונות קיימים

- **Form PF (ארה"ב):** קרנות פרטיות גדולות מדווחות ל-SEC על חשיפות ומנוף, בסודיות. מראה שרגולטורים כבר אוספים את המידע, אבל כל רגולטור בממגורה שלו, ושיתוף בין רגולטורים מוגבל משפטית.
- Abbe, Khandani ו-Lo, "Privacy-Preserving Methods for Sharing Financial Risk Exposures" (2012): מאמר שהציע בדיוק את הרעיון הזה, MPC לחישוב סיכון מערכתי. הוכחת היתכנות אקדמית, בלי מימוש בשטח.

- **Boston Women's Workforce Council (2015 ואילך):** מעסיקים בבוסטון שיתפו נתוני שכר דרך MPC כדי למדוד פערי שכר, בלי שאף מעסיק חשף את הנתונים שלו. הוכחה שגופים מתחרים מוכנים להשתתף כשיש מכנס אמין ומטרה משותפת.
- **Sharemind:** פלטפורמת MPC מסחרית שהופעלה באסטוניה לניתוח נתוני מס וחינוך. מוכיחה שהטכנולוגיה עובדת בקנה מידה ממשלתי.
- **ספריות MPC פתוחות:** MP-SPDZ, MPyC. כלי בנייה, לא פתרון.

מה מייחד אותנו: יישום ממוקד של MPC לבעיה הספציפית של חשיפות לריבית ולאשראי ממונף, עם סט שאלות מוגדר מראש שרגולטור באמת צריך, ושכבת הגנה על הפלט (כדי שהתשובה עצמה לא תסגיר משתתף).

ליבה טכנולוגית

הליבה הטכנולוגית היא פרוטוקול החישוב המשותף: פיצול כל ערך לחלקים אקראיים (secret sharing), כך שכל שרת מחזיק חלק שנראה כמו רעש, וביצוע חיבורים, השוואות ומכפלות ישירות על החלקים. רק בסוף, כשכל השרתים משלבים את החלקים של התוצאה, נפתח מספר אחד: התשובה המצרפית.

בלי הפרוטוקול הזה אין פרויקט: כל השאר (ממשק השאלות, הדוחות, הגנת הפלט) בנוי עליו.

טכנולוגיות עיקריות

- **MPyC:** ספריית MPC בפייתון, מבוססת Shamir secret sharing. בחרנו בה כי היא קריאה, מתועדת, ומתאימה ל-POC שבו רוצים להראות כל שלב.
- **Differential Privacy (דרך OpenDP):** הוספת רעש מבוקר לתוצאה, כדי שלא אפשר יהיה לחלץ מהתשובה המצרפית נתון של משתתף בודד (למשל, אם יש רק שלוש קרנות בענף).
- **gRPC עם TLS הדדי:** לתקשורת בין שרתי החישוב, עם זיהוי של כל צד.
- **Python ו-FastAPI:** לממשק שבו משתתף מעלה נתונים ורגולטור שואל שאלה.

מתלבטים:

- **MPC מול הצפנה הומומורפית (OpenFHE, TenSEAL):** הצפנה הומומורפית מאפשרת לשרת אחד לחשב על נתונים מוצפנים, בלי צורך בכמה שרתים שלא משתפים פעולה. אבל היא איטית בהרבה ומוגבלת בסוגי חישוב. MPC מהיר יותר אבל דורש הנחה ששרתים לא יתאמו ביניהם.
- **MPC מול סביבת מחשוב מאובטחת בחומרה (Intel SGX, AMD SEV):** מהירה מאוד, אבל דורשת לסמוך על יצרן המעבד, והיו בה פרצות ידועות.

אתגרים טכנולוגיים ומקורות מידע

- **בעיית התמריץ:** למה שקרן תשתתף? זה לא אתגר טכני אלא מבני, וחייבים לענות עליו כבר כאן. התשובה שלנו: המשתתפים הם לא קרנות מתנדבות, אלא רגולטורים שכבר אוספים את הנתונים בחובה (כמו Form PF). המערכת לא מבקשת מידע חדש, היא מאפשרת לשלב מידע שכבר נאסף אבל לא יכול לעבור בין רשויות. דוגמת בוסטון מראה שגם השתתפות מרצון אפשרית כשיש מכנס אמין.
- **ביצועים:** השוואות (למשל "האם ריבית מעל 5%?") יקרות ב-MPC בהרבה מחיבורים. צריך לבחור שאלות שאפשר לחשב בזמן סביר, ולמדוד.
- **הנחת אי-שיתוף פעולה:** האבטחה נשענת על כך שהשרתים לא יחברו את החלקים שלהם. צריך להגדיר מי מפעיל כל שרת (למשל כל רגולטור מפעיל אחד).

- **דליפה דרך התוצאה:** גם תשובה מצרפית יכולה להסגיר משתתף כשהקבוצה קטנה. לכן Differential Privacy וסף מינימלי של משתתפים לכל שאלה.

מקורות: תיעוד MP-SPDZ (github.com/data61/MP-SPDZ), MPyC (github.com/lschoe/mpyc), המאמר של Abbe, Khandani ו-Lo, ותיעוד OpenDP.

דרישות חומרה

אין חומרה מיוחדת. ל-POC מספיקים שלושה תהליכים על אותו מחשב שמדמים שלושה שרתים. בפריסה אמיתית, כל שרת אצל גוף אחר.

מסקנה

✅ שורד, עם התניה. הבסיס הקריפטוגרפי מוכח, ויש תקדימים אמיתיים לשימוש בו. ההתניה: בעיית התמריץ. במסמך הזה הצענו תשובה (רגולטורים שכבר אוספים בחובה), ובשלב המחקר נצטרך לבדוק שהתשובה מחזיקה, ושהחישוב מהיר מספיק כדי שרגולטור ישתמש בו.